OUTCALL DEEP AUDIT

Comprehensive Stability & UX Assessment

📅 March 13, 2026 🤖 Auditor: Antigravity AI 📂 243 Flutter + 6 Backend source files

SEVERITY	COUNT	CATEGORIES
CRITICAL	**4** findings	Stability (1), UX (1), Security (2)
IMPORTANT	**6** findings	Stability (4), UX (1), Quality (1)
POLISH	**5** findings	Stability (2), UX (2), Quality (1)

🔴 Critical — Fix Before Launch

#1 Splash Screen Shows Wrong Version

`splash_screen.dart — line 235`

The splash screen displays a hardcoded `'v1.5.0'`, but `pubspec.yaml` says `version: 2.0.0+40`. Every user sees a stale version on the very first screen.

> **Fix:** Replace with `PackageInfo.fromPlatform()` to dynamically fetch the real version.

⏱️ 15 min

#2 No Rate Limiting on API Endpoints

`main.py — /api/coach, /api/chat, /api/fingerprint`

All three endpoints have zero rate limiting. A bad actor or stuck retry loop could spam the Gemini API and burn through your quota or rack up charges.

> **Fix:** Add `slowapi` middleware (e.g., 10 req/min per IP for chat, 30/min for coach).

⏱️ 1 hour

#3 AI Coach System Prompt Is Only 3 Sentences

`services.py — lines 95-98`

This is the app's core differentiator and it has less instruction than the chatbot widget. No species-specific knowledge, no call technique context, no mistake-to-fix mappings, no guardrails against off-topic answers.

> **Fix:** Expand with species-specific coaching (reed pressure, tongue positioning, air flow), common mistakes per animal, and strict guardrails.

⏱️ 2–3 hours

#4 CORS Could Allow Wildcard in Production

`main.py — lines 12-28`

If `ALLOWED_ORIGINS=*` is accidentally set in Railway env vars, the backend accepts requests from any website — letting third parties use your Gemini API for free.

> **Fix:** Block `*` when `RAILWAY_ENVIRONMENT=production`. Log a warning if detected.

⏱️ 15 min

🟡 Important — Improve Stability & UX

#5 Offline State Doesn't Guard API Calls

`connectivity_provider.dart, offline_banner.dart`

`isOfflineProvider` exists but only powers a passive UI banner. AI coach, leaderboard submit, and fingerprint calls fire without connectivity checks — resulting in raw HTTP errors instead of friendly offline messaging.

> **Fix:** Wrap all REST calls with `isOfflineProvider` checks and show graceful fallback UI.

⏱️ 2–3 hours

#6 No Retry on Cloud Audio Download Failure

`cloud_audio_service.dart — lines 69-103`

Premium calls' audio downloads have no retry logic. In the field (literal hunting fields), network is spotty — users get a hard error with no recourse.

> **Fix:** Add exponential backoff retry (3 attempts) and "Tap to retry" UI state.

⏱️ 1–2 hours

#7 Achievement Check Fires 3 Sequential Firestore Round-Trips

`rating_screen.dart — lines 154-196`

`_checkForAchievements()` calls `loadProfile` → `saveAchievements` → `loadProfile` again, adding 3+ seconds of latency to every analysis result screen on slow connections.

> **Fix:** Batch into a single write transaction or optimistically update local state.

⏱️ **1 hour**

#8 Possible Feature Extraction Mismatch (RF Classifier)

`services.py vs training_pipeline.py`

Training and inference may extract different feature counts. If they don't match exactly, the Random Forest produces garbage predictions silently.

> **Fix:** Assert `len(features) == clf.n_features_in_` and run a round-trip validation test.

⏱️ **1 hour**

#9 RF Classifier Likely Never Runs in Production

`services.py — line 205`

The classifier needs `audioFilePath` to extract features, but the Flutter app sends only metrics to `/api/coach` — not the raw audio file. The classifier always returns `"unknown", 0.0`.

> **Fix:** Architectural decision needed — upload WAV, restructure RF to use metrics, or document as inert.

⏱️ **Discussion required**

#10 Deprecated FastAPI Startup Event Pattern

`main.py — line 30`

`@app.on_event("startup")` is deprecated. Future FastAPI versions will drop support.

> **Fix:** Migrate to `@asynccontextmanager lifespan(app)` pattern.

⏱️ **15 min**

🟢 Polish — Nice-to-Have

#11 Test Coverage: 20%

`test/ — 48 test files vs 243 source files`

Recording, payment, cloud audio, fingerprint, daily challenge, leaderboard, and progress map features have minimal or no dedicated tests.

> **Priority:** Recording lifecycle, payment flow, CloudAudioService resolution, AI coach fallback.

⏱️ Days (ongoing)

#12 Chat Ignores Conversation History

`services.py — line 289`

`get_chat_response()` accepts a `history` parameter but only passes the current message to Gemini — multi-turn conversations are incoherent.

> **Fix:** Format history into Gemini's `contents` array as alternating user/model turns.

⏱️ 1 hour

#13 "Within Tolerance ✔️" Badge Is Always Shown

`rating_screen.dart — line 630`

The tolerance badge is hardcoded to always display. A user 300Hz off-target still sees "Within tolerance ✔️".

> **Fix:** Conditionally render based on `(userPitch - targetPitch).abs() <= tolerancePitch`.

⏱️ 15 min

#14 Undocumented record_linux Override

`pubspec.yaml — dependency_overrides`

`record_linux: 1.3.0` is pinned without documentation. Could mask future breaking changes.

⏱️ 5 min

#15 Splash Not Clamped by Text Scaler

`splash_screen.dart`

Text scaling clamp (0.8–1.35x) only applies inside `MaterialApp`, but splash renders before it. Extreme accessibility settings could break layout.

⏱️ 15 min (low priority)

✅ What's Already Done Well

🛡️ **ERROR HANDLING**
Global `PlatformDispatcher.onError` + Crashlytics + `FlutterError.onError` trifecta

🧩 **DI ARCHITECTURE**
Clean platform-aware DI matrix (Firebase / Firedart / Mock) with proper dispose

🎵 **AUDIO ANALYSIS**
1,336-line analyzer with chunk-based WAV parsing, isolate compute, spectral subtraction

💳 **PAYMENT**
Proper IAP lifecycle with stream subscription, pending tracking, desktop mock

🎨 **UI POLISH**
Safe `_tryRender` wrapper, haptics, animated splash, achievement celebrations

🔐 **AUTH**
Multi-platform auth with proper pre-initialization on desktop

🔄 **GEMINI FAILOVER**
Primary/backup API key rotation with automatic switch-on-failure

📱 **ACCESSIBILITY**
Text scaling clamp, semantic labels, 48×48 touch targets documented

🎯 RECOMMENDED FIX ORDER

▸ BEFORE LAUNCH (THIS WEEK)

1. Fix splash version string — 15 min
2. Fix "Within tolerance" hardcoded badge — 15 min
3. Add rate limiting to backend — 1 hour
4. Validate CORS in production — 15 min

▸ BEFORE SCALING (NEXT SPRINT)

5. Expand COACH_SYSTEM_PROMPT — 2–3 hours
6. Guard API calls with offline checks — 2–3 hours
7. Add retry to CloudAudioService — 1–2 hours
8. Fix achievement Firestore round-trips — 1 hour
9. Wire chat history into Gemini — 1 hour
10. Resolve RF classifier architecture — discussion

▸ **ONGOING**

11. Expand test coverage (critical paths first)

OUTCALL Deep Audit — Prepared by Antigravity AI · March 13, 2026 · Confidential